

Vulnerability Assessment Report

Limited service scan and passive web security review of a public demonstration login page.

Prepared for
Future Interns Cyber Security Internship

Prepared by
Keerit Kapoor

Assessment date
20 June 2026

Target
<http://testaspnet.vulnweb.com/login.aspx>

ASSESSMENT BOUNDARY

Authorised public demonstration target. Activity was limited to one targeted Nmap service-identification scan on TCP/80, browser DevTools inspection, and OWASP ZAP in Safe Mode using passive scanning. No exploitation was performed.

Document control and executive summary

Field	Details
Report title	Vulnerability Assessment Report - Task 1
Prepared by	Keerit Kapoor
Target	http://testaspnet.vulnweb.com/login.aspx
Assessment approach	Targeted TCP/80 service identification plus passive web-application review
Tools	Nmap 7.99, OWASP ZAP 2.17.0 in Safe Mode, Browser DevTools
Classification	Educational portfolio report; public demonstration environment

Executive summary

This report documents a limited security assessment of an Acunetix public demonstration login page. The review was intentionally constrained: one targeted service-identification scan checked TCP/80, while OWASP ZAP was operated in Safe Mode to collect passive alerts from normal browser traffic. No payloads, automated attack scans, login attempts, or exploitation were performed.

The evidence supports one High-severity transport-security finding, one Medium-severity passive alert that requires validation, and one Low-severity technology-disclosure finding. Several additional ZAP alerts are recorded as hardening observations, not confirmed exploit findings.

Severity	Count	Included assessment result
High	1	Login page delivered over HTTP
Medium	1	Potential absence of anti-CSRF tokens - ZAP passive alert, low confidence
Low	1	Server and framework version disclosure

Priority action

The most important corrective action is to prevent a usable authentication experience from being delivered over HTTP. Redirect HTTP requests to HTTPS before login content appears and then validate the configuration.

Scope, safeguards and methodology

Included	Excluded
Target URL, TCP/80 service identification, login-page transport state, visible response headers, ZAP passive alerts created from normal browsing traffic.	Credential submission, authentication testing, SQL injection, XSS, brute force, fuzzing, directory enumeration, active scanning, and exploitation.

Tools used

Tool	Use during assessment	Evidence produced
Nmap 7.99	Limited version/service identification against the authorised target on TCP/80 only.	Open HTTP service identified as Microsoft IIS httpd 8.5.
OWASP ZAP 2.17.0	Safe Mode; browser traffic observed through the proxy; passive scanning only.	Passive alerts for CSRF protection, headers, cookies, and technology disclosure.
Browser DevTools	Network request and response-header inspection.	HTTP URL, 200 response, IIS/ASP.NET header values.

Methodology

- **1. Target validation:** opened the public demonstration login page and confirmed it rendered successfully.
- **2. Service identification:** ran `nmap -sV -p 80 testaspnet.vulnweb.com`. The scope was restricted to one web port.
- **3. Browser inspection:** used DevTools Network to review the document request and visible response headers.
- **4. Passive proxy review:** launched Edge from OWASP ZAP, set ZAP to Safe Mode, browsed only to the login page, and reviewed the resulting passive alerts.
- **5. Reporting:** documented evidence, impact, remediation, limitations, and validation requirements.

Rules of engagement observed

The activity did not include an active scan, attack payloads, password attempts, form submissions, changes to the target, or attempts to access data. The selected target is an openly published training and demonstration environment.

Assessment evidence inventory

The following evidence was captured during the assessment. The Nmap output confirms that the target is reachable and that the HTTP service on port 80 identifies itself as Microsoft IIS httpd 8.5. An open service is not a vulnerability by itself; the result is used to support technology identification and scope validation.

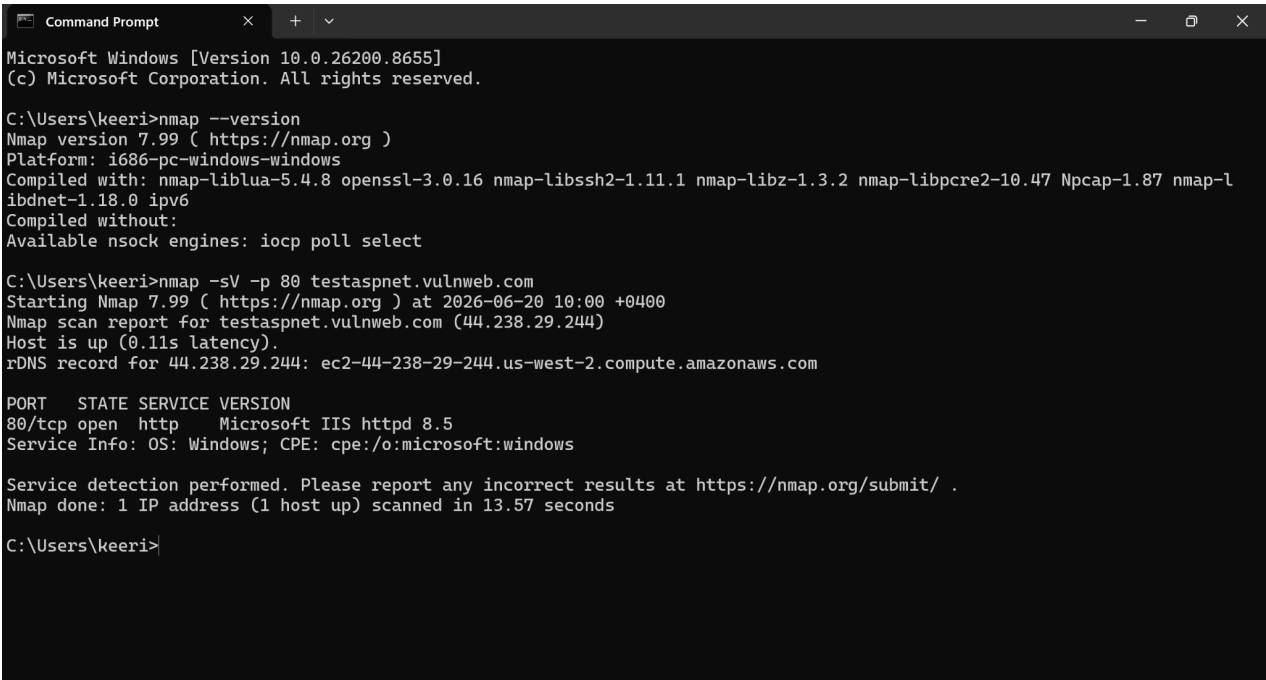


Figure 1. Targeted Nmap service-identification scan on TCP/80. The command was limited to the authorised web service and shows Microsoft IIS httpd 8.5.

Evidence file	What it supports
http_login_page.png	HTTP-delivered login page and browser "Not secure" warning.
response_headers.png	Document response details and exposed IIS / ASP.NET headers.
nmap_port_80.png	Target reachability, TCP/80 availability, and service identification.
zap_passive_alerts.png	ZAP Safe Mode passive alert list and selected anti-CSRF observation.

Finding CS-01

Sensitive login page served over unencrypted HTTP

HIGH

Finding ID	CS-01	Category	Transport security
Severity	High	Affected URL	http://testaspnet.vulnweb.com/login.aspx

Description

The login page is rendered with a username and password form while the browser shows a "Not secure" warning and the URL uses HTTP. HTTP does not encrypt or protect the integrity of traffic between the user and the application.

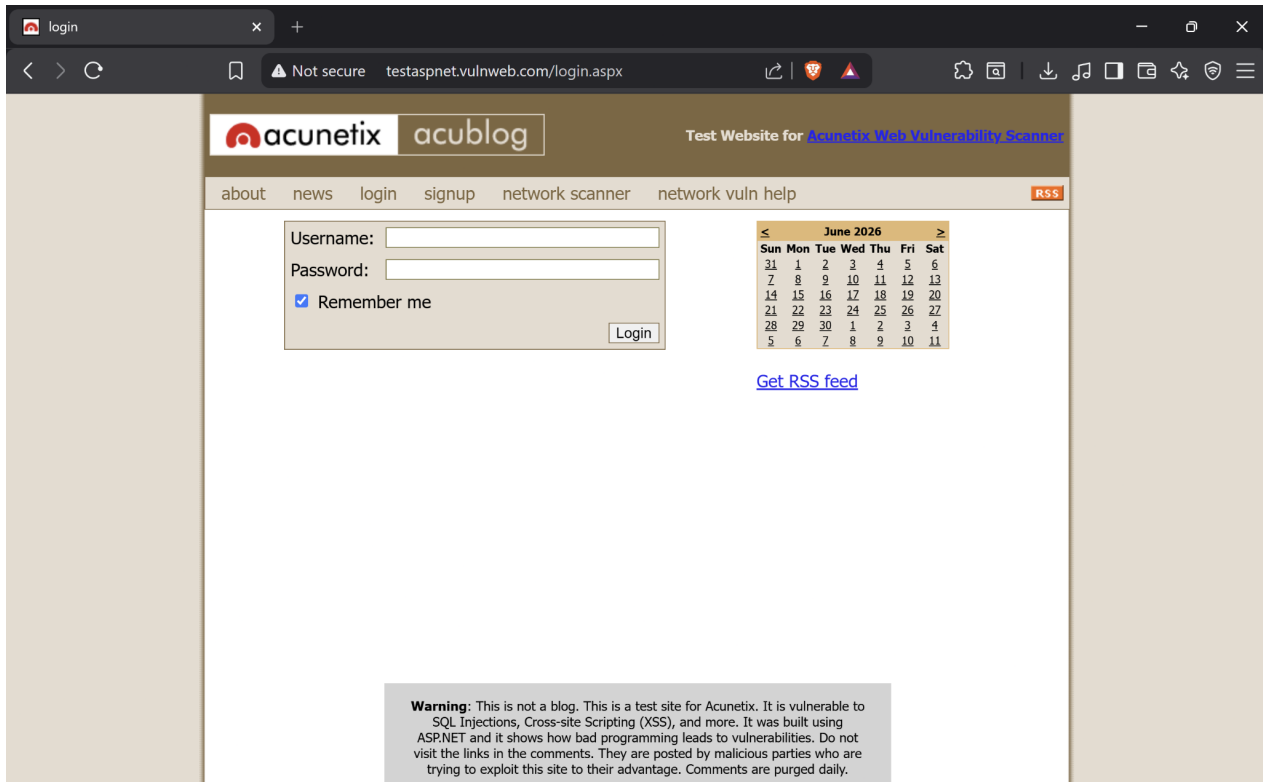


Figure 2. Browser evidence of the HTTP login page. The address bar shows "Not secure" while a username/password form is visible.

Potential impact

When real users access an HTTP-delivered login interface on an untrusted network, traffic could potentially be observed or altered in transit. This can create risk of credential exposure, content manipulation, session compromise, and loss of user trust. The form submission was not tested, so this report does not claim proof that credentials were transmitted in clear text.

Finding CS-01 - remediation

Priority	Recommended action	Validation check
Immediate	Serve the login page and all authentication endpoints over HTTPS only. Redirect HTTP before form content is returned.	Opening the HTTP URL redirects to HTTPS before the form is shown.
High	Deploy HSTS after HTTPS is fully tested.	HTTPS response includes Strict-Transport-Security.
High	Set Secure, HttpOnly, and appropriate SameSite attributes for authentication cookies.	Set-Cookie headers show approved flags and authentication cookies are not issued over HTTP.

Finding CS-02

Server and framework information disclosure

LOW

The browser response headers expose **Server: Microsoft-IIS/8.5**, **X-AspNet-Version: 2.0.50727**, and **X-Powered-By: ASP.NET**. The Nmap service-identification result independently reports Microsoft IIS httpd 8.5 on port 80. This does not prove a flaw in the server, but it makes technology fingerprinting and version-specific research easier.

Recommendation: suppress unnecessary server and framework version headers where operationally feasible; keep the web server and framework on supported, patched versions; confirm the change through a fresh header review.

Finding CS-02 - evidence

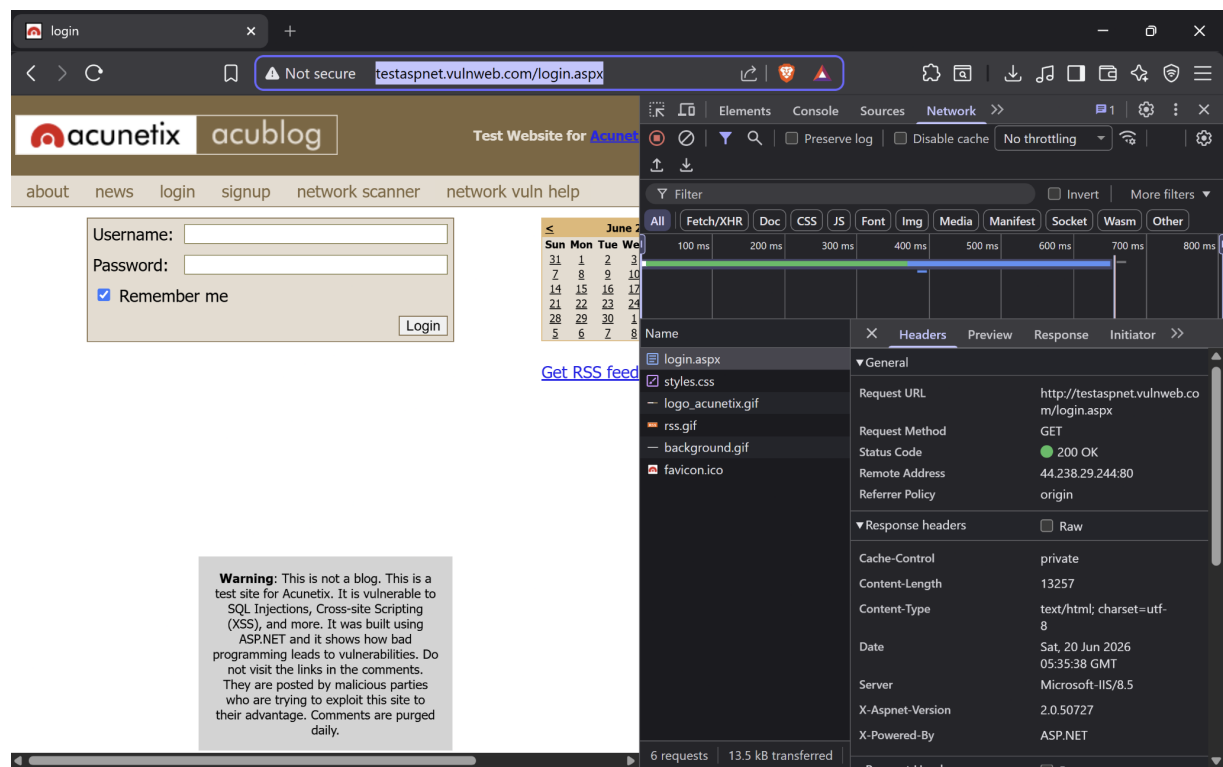


Figure 3. Browser DevTools response headers show Microsoft-IIS/8.5, X-AspNet-Version: 2.0.50727, and X-Powered-By: ASP.NET.

Why it matters	Remediation approach
Detailed technology headers reduce the effort required to identify the application stack and locate version-specific public information.	Remove avoidable product/version disclosure, maintain patching, and repeat the header review after configuration changes.

Evidence linkage

The result is supported by both browser DevTools and the limited Nmap scan. The service identification is documented as information disclosure and is not treated as a vulnerability solely because port 80 is open.

Finding CS-03

Potential absence of anti-CSRF tokens - passive alert

MEDIUM

Finding ID	CS-03	Source	OWASP ZAP passive alert 10202
Risk	Medium	Confidence	Low - as displayed by ZAP

Description

ZAP in Safe Mode recorded a passive alert titled "Absence of Anti-CSRF Tokens" for the login form. The alert details show a Medium risk rating with Low confidence. Because this conclusion came from passive analysis alone and the scope did not include active validation, it is documented as a potential issue that requires validation by the application owner.

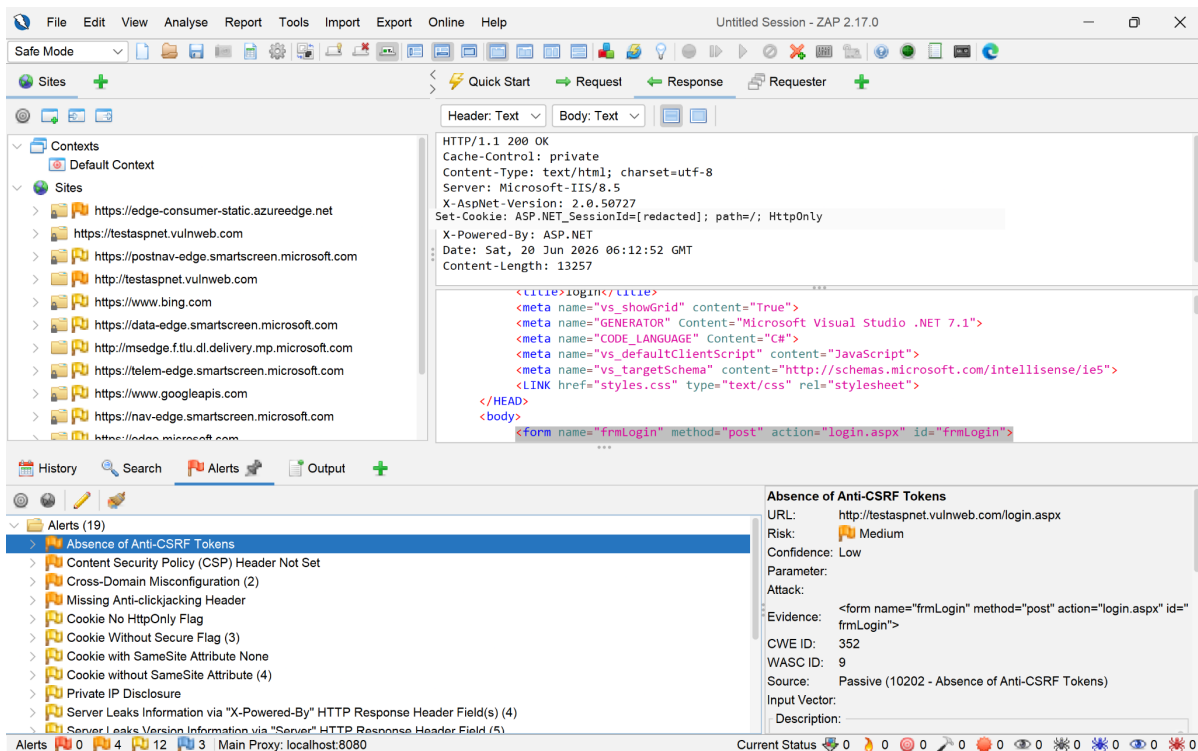


Figure 4. OWASP ZAP 2.17.0 in Safe Mode. The selected passive alert is "Absence of Anti-CSRF Tokens" for the login URL. Incidental session value in the response pane has been redacted.

Passive observations and remediation plan

In addition to CS-03, the ZAP alert list displayed several relevant defensive-control observations. These are shown below as items for configuration review. They should be validated before being treated as confirmed vulnerabilities because the assessment intentionally excluded active testing.

Passive observation visible in ZAP	Why it matters	Recommended configuration review
Content Security Policy (CSP) Header Not Set	A CSP helps reduce exposure to certain content-injection impacts.	Define and deploy an application-appropriate CSP after testing.
Missing Anti-clickjacking Header	Pages may be more exposed to UI redress/clickjacking scenarios.	Use CSP frame-ancestors and/or X-Frame-Options where appropriate.
Cookie Without Secure Flag / SameSite Attribute	Cookie transport and cross-site behavior may not be sufficiently restricted.	Set Secure, HttpOnly, and appropriate SameSite values for session cookies.
Server leaks information via X-Powered-By / Server headers	Confirms the technology-disclosure theme observed in DevTools.	Suppress avoidable product/version headers.

Suggested remediation sequence

Phase	Action	Success criterion
1 - Immediate	Enforce HTTPS and remove the usable HTTP login experience.	Browser lands on HTTPS before the login form appears.
2 - Hardening	Review CSRF protection, cookie flags, CSP, frame protections, and HSTS.	Controls are documented, tested, and visible in the resulting responses.
3 - Hygiene	Reduce unnecessary server/framework disclosure and maintain patching.	External header review exposes less avoidable stack detail.
4 - Retest	Repeat limited service scan and passive browser/ZAP review after changes.	Evidence shows the protected configuration and any validated findings are closed.

Limitations, conclusion and evidence index

Assessment limitations

- The Nmap activity was limited to service/version detection against TCP/80. It did not scan all ports, run scripts, or use OS detection.
- OWASP ZAP was operated in Safe Mode and used only passive scanning of normal browser traffic.
- No credentials were entered, no login request was submitted, and no authenticated functionality was assessed.
- No SQL injection, XSS, brute force, fuzzing, directory enumeration, active scan, or exploitation was performed.
- The report does not provide a complete security assurance statement. Findings not observed in this constrained review may still exist.

Conclusion

The review identified a clear transport-security weakness: a login page is delivered over HTTP. That condition should be prioritised because authentication content should be protected by HTTPS before users can interact with it. The assessment also documented server/framework information disclosure and a ZAP passive alert indicating potential missing anti-CSRF protection, with Low confidence and no active validation. Addressing these items and completing a controlled retest would improve the application security posture.

Evidence index

Repository file	Used in report
screenshots/http_login_page.png	CS-01 transport-security evidence
screenshots/response_headers.png	CS-02 response-header evidence
screenshots/nmap_port_80.png	Limited service-identification evidence
screenshots/zap_passive_alerts.png	CS-03 ZAP Safe Mode passive alert evidence

References

- [1] OWASP Web Security Testing Guide - information gathering and testing methodology.
- [2] OWASP Transport Layer Security Cheat Sheet.
- [3] OWASP Cross-Site Request Forgery Prevention Cheat Sheet.
- [4] Nmap Reference Guide - service and version detection.
- [5] OWASP ZAP documentation - Safe Mode and passive scanning.

Repository submission note

Replace the earlier PDF in the GitHub repository with this updated report so that the written report reflects the Nmap and OWASP ZAP evidence now included in the screenshots folder.